

Marco integrativo GQM + PRAGMATIC para indicadores SIEM

Versión 1.0 – Enfoque para conectar objetivos nacionales de ciberseguridad con métricas técnicas SIEM y evaluar su calidad.

1. Introducción

Este documento define un marco integrativo que combina la metodología GQM (Goal–Question–Metric) con los criterios PRAGMATIC para diseñar, seleccionar y evaluar indicadores SIEM desde la perspectiva de objetivos nacionales y sectoriales de ciberseguridad.

1.1 Objetivo del marco

- Asegurar trazabilidad explícita desde los objetivos estratégicos (nivel país, sector y organización) hasta las métricas técnicas del SIEM.
- Evaluar cada métrica con los nueve criterios PRAGMATIC: Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente y Rentable.
- Proporcionar una base homogénea para cuadros de mando nacionales, sectoriales y corporativos, alineada con NIS2, ENS, DORA y guías de ENISA.

1.2 Contexto SIEM/SOC

El marco parte de la función actual del SIEM como:

- Motor de detección y respuesta (SOC).
- Fuente de evidencia para cumplimiento normativo (NIS2, ENS, reguladores sectoriales).
- Componente clave de la evaluación de resiliencia y de los índices de madurez nacionales.

2. Resumen del enfoque GQM aplicado a SIEM

La metodología GQM se estructura en tres niveles:

- Goal (G) – Objetivo de alto nivel, formulado en términos de riesgo país, resiliencia, cumplimiento o eficacia operativa.
- Question (Q) – Preguntas que permiten evaluar si el objetivo se está cumpliendo, expresadas en lenguaje de negocio, regulación y riesgo.
- Metric (M) – Métricas cuantitativas y cualitativas derivadas de las preguntas, implementables con datos del SIEM y sistemas relacionados (ticketing, CMDB, herramientas de riesgo, etc.).

En el contexto SIEM, cada objetivo se conecta con:

- Indicadores de operación SOC (MTTD, MTTR, falsos positivos, cobertura).
- Indicadores de cumplimiento (plazos de notificación, calidad de evidencias, número de incidentes reportados).
- Indicadores de riesgo (frecuencia de incidentes graves, impacto, exposición).
- Indicadores de modernización (uso de IA, automatización, monitorización OT/5G).

El resultado es una cadena explícita:

Objetivo estratégico – Preguntas de negocio/regulación – Métricas SIEM instrumentadas.

3. Integración con PRAGMATIC

La metodología PRAGMATIC introduce un conjunto de criterios para evaluar la “salud” de cada métrica:

- P – Predictivo: capacidad de anticipar comportamientos futuros, tendencias de amenaza o degradación de controles, más allá de describir el pasado.
- R – Relevante: alineación con objetivos clave del país, sector, regulador y organización.
- A – Accionable: capacidad de sugerir acciones concretas cuando la métrica cambia (por ejemplo, reforzar controles, ajustar staffing, modificar casos de uso).
- G – Genuino: fidelidad con la realidad que pretende medir; ausencia de distorsiones sistemáticas o incentivos perversos.
- M – Significativo (Meaningful): inteligibilidad y capacidad de aportar significado a las partes interesadas (CISO, negocio, regulador, gobierno).
- P – Preciso (Precise): grado de exactitud, claridad de definición y ausencia de ambigüedades.
- T – Oportuno (Timely): capacidad de obtener la métrica con la frecuencia y latencia necesarias para que sea útil.
- I – Independiente: robustez frente a la manipulación, dependencia de una sola fuente o subjetividad excesiva.
- C – Rentable (Cost-effective): relación coste/beneficio razonable para la recogida, tratamiento y mantenimiento de la métrica.

Cada criterio se puntúa en una escala 0–3:

- 0 = No cumple / muy débil.
- 1 = Cumple parcialmente.
- 2 = Cumple adecuadamente.
- 3 = Cumple de forma excelente.

La **puntuación PRAGMATIC global** de una métrica puede obtenerse como suma o media de los nueve criterios, estableciendo umbrales:

- < 12: métrica de baja calidad; reconsiderar seriamente su uso.
- 12–20: métrica aceptable, pero con áreas claras de mejora.
-

20: métrica robusta; candidata a KPI estratégico.

20: métrica robusta; candidata a KPI estratégico.

4. Objetivos GQM clave (nivel nacional/sectorial)

A partir del informe de indicadores SIEM, se proponen los siguientes objetivos G de referencia:

G1 – Reducir el tiempo de detección y respuesta a incidentes graves en sectores esenciales

- Motivación: limitar el impacto de ataques críticos (ransomware, intrusión en OT, fraude masivo).
- Ámbito: operadores esenciales e importantes, administración, infraestructuras críticas.
- Relación normativa: NIS2 (art. 21 y 23), ENS (gestión de incidentes), DORA (resiliencia operativa).

Ejemplos de preguntas:

- Q1.1: ¿Cuál es el tiempo medio de detección (MTTD) de incidentes de criticidad alta?
- Q1.2: ¿Cuál es el tiempo medio de respuesta/contención (MTTR) de esos incidentes?
- Q1.3: ¿Cómo varían MTTD y MTTR por tipo de amenaza (ransomware, exfiltración, fraude) y por sector?

Ejemplos de métricas:

- M1.1: MTTD medio para incidentes críticos (en minutos).
- M1.2: MTTR medio hasta contención para incidentes críticos (en minutos).
- M1.3: Distribución de MTTD por categoría de incidente y sector.

G2 – Asegurar el cumplimiento efectivo de las obligaciones de notificación de incidentes

- Motivación: evitar incumplimientos de NIS2, ENS y normativa sectorial; mejorar coordinación con CERT nacionales.
- Ámbito: entidades sujetas a NIS2, ENS, DORA u otras regulaciones análogas.
- Relación normativa: NIS2 art. 23, ENS (gestión de incidentes), reguladores sectoriales.

Preguntas:

- Q2.1: ¿Cuánto tiempo transcurre, de media, desde la detección hasta la notificación oficial?
- Q2.2: ¿Qué porcentaje de incidentes sujetos a notificación se comunican dentro de los plazos legales?
- Q2.3: ¿Cuál es el nivel de completitud de las evidencias técnicas incluidas en los informes?

Métricas:

- M2.1: Tiempo medio detección-notificación (horas).
- M2.2: % de incidentes notificados dentro de plazo legal.
- M2.3: Índice de completitud de evidencias (0–100).

G3 – Mejorar la calidad y la cobertura de la monitorización de activos críticos (IT/OT/5G)

- Motivación: asegurar que los activos más importantes están bajo vigilancia efectiva.
- Ámbito: activos críticos definidos por NIS2, ENS, estrategias sectoriales.
- Relación normativa: NIS2 art. 21, ENS (medidas organizativas y técnicas), guías ENISA OT/5G.

Preguntas:

- Q3.1: ¿Qué porcentaje de activos críticos envía logs relevantes al SIEM?
- Q3.2: ¿Qué porcentaje de técnicas MITRE ATT&CK relevantes está cubierto por casos de uso?
- Q3.3: ¿Cuál es la latencia media de ingesta y correlación de eventos críticos?

Métricas:

- M3.1: Cobertura de activos críticos monitorizados (%).
- M3.2: Cobertura de técnicas ATT&CK relevantes (%).
- M3.3: Latencia de ingesta de eventos críticos (segundos/minutos).

G4 – Incrementar el uso efectivo de IA y automatización en el SOC

- Motivación: reducir la fatiga de alertas, aumentar la precisión y liberar capacidad humana.
- Ámbito: SOC internos, híbridos o externalizados con capacidades SIEM/XDR/SOAR.
- Relación normativa: NIS2 art. 21 (medidas técnicas), DORA (tecnologías de supervisión).

Preguntas:

- Q4.1: ¿Qué porcentaje de detecciones deriva de modelos de IA/UEBA?
- Q4.2: ¿Qué porcentaje de incidentes se resuelve parcial o totalmente mediante automatización?
- Q4.3: ¿Cómo afecta la IA a la tasa de falsos positivos y a la carga por analista?

Métricas:

- M4.1: % de detecciones impulsadas por IA/UEBA.
- M4.2: % de incidentes con respuesta automatizada.
- M4.3: Variación de falsos positivos antes/después de IA ($\Delta\%$).

G5 – Integrar los indicadores SIEM en la gestión de riesgos y la toma de decisiones de inversión

- Motivación: convertir el SIEM en herramienta de gestión de riesgo y ROI, no solo en centro de coste.
- Ámbito: áreas de riesgo, negocio, auditoría, alta dirección.
- Relación normativa: NIS2 art. 21 (gestión de riesgos), ENS (análisis de riesgos), DORA.

Preguntas:

- Q5.1: ¿Con qué frecuencia se utilizan métricas SIEM en comités de riesgo?
- Q5.2: ¿Se utilizan métricas SIEM para justificar inversiones y priorizar proyectos?
- Q5.3: ¿Cuál es la frecuencia de incidentes graves y la estimación de pérdidas evitadas?

Métricas:

- M5.1: % de reuniones de riesgo/comités donde se presentan métricas SIEM.
- M5.2: Frecuencia anual de incidentes graves.
- M5.3: Estimación anual de pérdidas evitadas (en €) atribuibles a mejoras en detección/respuesta.

5. Uso del marco en práctica

1. Definir o validar los objetivos G relevantes para el contexto nacional o sectorial.
2. Derivar las preguntas Q que los decisores realmente quieren responder.
3. Seleccionar un conjunto manejable de métricas M por objetivo.
4. Evaluar cada métrica con PRAGMATIC y priorizar las de mayor calidad.
5. Integrar las métricas resultantes en:
6. Encuestas a organizaciones.
7. Cuadros de mando nacionales/sectoriales.
8. Plantillas de IGM y ROI.

Fin del marco integrativo.